

Adaptive Authentication with Behavioral Biometrics

Requirements Gathering Document

Document Version:	2.0
Prepared For:	Academic Graduation Project Evaluation
Domain:	Cybersecurity / Artificial Intelligence
Platform Target:	Web Applications
Date:	2025-2026
Classification:	Confidential — Academic Use Only

Table of Contents

1. Stakeholder Analysis	3
1.1 Overview.....	3
1.2 Stakeholder Identification & Classification.....	3
1.3 Stakeholder Needs & Expectations	4
1.4 Stakeholder Influence-Interest Matrix	5
2. User Stories & Use Cases	6
2.1 User Personas.....	6
2.2 User Stories.....	6
2.3 Use Case Descriptions	8
3. Functional Requirements	13
3.1 Overview.....	13
3.2 Authentication & Session Management	13
3.3 Behavioral Data Collection	13
3.4 Behavioral Profile Management	14
3.5 Anomaly Detection & Risk Scoring.....	14
3.6 Adaptive Response — Step-Up Authentication.....	15
3.7 Automatic Session Termination.....	15
3.8 Admin Dashboard & Monitoring.....	16
3.9 API & Integration.....	16
4. Non-Functional Requirements	18
4.1 Overview.....	18
4.2 Performance Requirements.....	18
4.3 Security Requirements	18
4.4 Usability Requirements	19
4.5 Reliability Requirements	20
4.6 Scalability Requirements	21
4.7 Maintainability Requirements	22

1. Stakeholder Analysis

1.1 Overview

Stakeholder analysis is a critical first step in requirements gathering. It identifies all individuals, groups, and organizations that have a direct or indirect interest in the Adaptive Authentication system — whether as end users, decision-makers, integrators, or regulators. Understanding stakeholder needs, expectations, and influence levels ensures that the system design is aligned with real-world requirements and that no critical perspective is overlooked.

1.2 Stakeholder Identification & Classification

Stakeholder	Type	Role & Description	Influence	Interest
End Users (Employees / Customers)	Primary	Individuals who log into and actively use applications protected by the behavioral authentication system. Their experience directly determines adoption success.	Medium	High
Application Owners / Product Managers	Primary	Teams responsible for web or mobile applications that integrate the authentication SDK. They define integration requirements and own the user experience.	High	High
IT Security Team	Primary	Internal security professionals responsible for defining security policies, reviewing threat models, and approving the system's compliance with security standards.	High	High
System Administrators	Primary	Operations personnel who manage the deployed system, monitor anomaly alerts, configure thresholds, and respond to security incidents via the admin dashboard.	High	High
ML / Data Engineering Team	Primary	Responsible for training, validating, and maintaining the behavioral biometrics anomaly detection models. They own model quality and retraining pipelines.	High	High
Backend Development Team	Primary	Engineers who implement the microservices (Auth Service, Behavior Collector, ML Inference Engine). They translate functional requirements into working software.	High	High
Frontend / SDK Development Team	Primary	Developers who build the React.js admin dashboard and the JavaScript / React Native behavioral data collection SDKs.	High	Medium
Academic Supervisors / Evaluators	Secondary	Faculty members and evaluators who assess the project against academic and technical standards. Their feedback shapes deliverable quality.	High	Medium

Stakeholder	Type	Role & Description	Influence	Interest
Compliance / Legal Officers	Secondary	Professionals responsible for ensuring the system adheres to data privacy regulations (GDPR, PDPA, ISO/IEC 27001). They review data handling and retention policies.	Medium	Medium
Third-party Integrators	External	Organizations or developers who consume the system's REST APIs to embed behavioral authentication into their own applications or platforms.	Low	High
Regulatory Bodies	External	Government and industry bodies (e.g., data protection authorities) that set legal frameworks governing biometric and behavioral data processing.	High	Low

Table 1.1 — Stakeholder Identification & Classification

1.3 Stakeholder Needs & Expectations

Stakeholder	Primary Needs	Key Expectations	Success Criteria
End Users	Transparent, frictionless authentication that does not disrupt normal workflows.	Minimal false challenges; clear explanations when step-up auth is triggered; privacy of behavioral data.	< 2% false step-up rate; step-up completed in < 30 seconds.
Application Owners	Easy SDK integration, detailed API documentation, and measurable security improvements.	Drop-in SDK integration within 1 sprint; reliable uptime; compliance-ready data handling.	Integration time ≤ 2 weeks; system uptime $\geq 99.9\%$.
IT Security Team	Robust threat detection, comprehensive audit logging, and full visibility into system behavior.	Detection rate > 92%; real-time alerting; exportable audit logs; pen-test-verified security.	TPR $\geq 92\%$; FPR $\leq 5\%$; zero critical vulnerabilities in security audit.
System Admins	Intuitive dashboard for monitoring, alerting, and threshold configuration.	Real-time session visibility; one-click session termination; alert prioritization.	Admin actions (terminate session) executed in < 2 seconds.
ML / Data Eng. Team	Clean, accessible data pipelines and reproducible model training infrastructure.	Well-documented feature engineering; automated retraining triggers; version-controlled models.	AUC-ROC ≥ 0.95 ; model drift < 3%/month.
Compliance Officers	Demonstrable compliance with data privacy regulations and secure data handling practices.	No raw behavioral data stored; clear data retention policies; user consent mechanism.	Zero privacy violations; documented data flow and retention policies.
Third-party Integrators	Well-documented, stable, versioned REST APIs with sandbox testing environment.	OpenAPI 3.0 documentation; backward-compatible versioning; SDKs with example code.	API integration achievable within 1 week for experienced developer.

Table 1.2 — Stakeholder Needs, Expectations & Success Criteria

1.4 Stakeholder Influence-Interest Matrix

Stakeholders are mapped across a 2x2 Influence-Interest matrix to determine the appropriate engagement strategy for each group throughout the project lifecycle.

	Low Interest	High Interest
High Influence	Regulatory Bodies, Compliance Officers → Strategy: Keep Satisfied — consult on compliance requirements; provide regular compliance reports.	IT Security Team, System Administrators, Application Owners, Academic Supervisors → Strategy: Manage Closely — involve in design reviews, weekly status updates, sign-off gates.
Low Influence	(No identified stakeholders in this quadrant)	End Users, Third-party Integrators → Strategy: Keep Informed — provide release notes, user guides, API changelogs, and feedback channels.

Figure 1.1 — Stakeholder Influence-Interest Matrix

2. User Stories & Use Cases

2.1 User Personas

Three primary user personas have been defined to ground user stories and use cases in realistic usage contexts.

Persona	Role	Technical Proficiency	Primary Goal	Pain Points
Alex	End User — Bank Customer	Low — uses mobile app daily for financial transactions.	Access accounts securely without remembering complex passwords or being interrupted.	Frustrated by repeated OTP prompts; concerned about account takeover.
Sarah	System Administrator — Security Ops	High — manages enterprise security tools and dashboards.	Monitor all active sessions in real time and respond to anomaly alerts quickly.	Alert fatigue from high false positive rates; lacks session-level behavioral insights.
Omar	Backend Developer — Third-party Integrator	High — integrates security APIs into enterprise web applications.	Integrate the behavioral authentication SDK into an existing app within one sprint.	Poor API documentation; breaking changes between versions; no sandbox environment.

Table 2.1 — User Personas

2.2 User Stories

User stories are written in the standard format: As a [role], I want to [action], so that [benefit]. Each story includes an acceptance criteria summary and a priority rating.

Story ID	User Story	Acceptance Criteria	Priority
US-01	As an end user, I want to log into the application using my email and password, so that I can access my account securely.	Login succeeds with valid credentials; fails with invalid ones; JWT token issued with expiry; behavioral SDK activates on successful login.	Critical
US-02	As an end user, I want the system to monitor my behavior silently in the background, so that my normal session is not interrupted by unnecessary challenges.	SDK captures events asynchronously with < 5% overhead; no visible impact on app performance; user is unaware of monitoring.	Critical
US-03	As an end user, I want to be prompted for additional verification only when unusual activity is detected, so that I am protected without unnecessary friction.	Step-up prompt appears when risk score > 0.65; prompt is clear and actionable; legitimate users challenged < 2% of the time.	Critical

Story ID	User Story	Acceptance Criteria	Priority
US-04	As an end user, I want to complete a step-up authentication challenge via OTP, so that I can prove my identity and resume my session.	OTP sent within 5 seconds; valid OTP restores session; invalid OTP shows error; session terminated after 3 failed attempts.	High
US-05	As an end user, I want to be automatically logged out if suspicious activity is detected and I fail re-authentication, so that my account remains protected.	Session terminated when risk score > 0.90 and step-up fails; user redirected to login with explanatory message; event logged.	High
US-06	As a system administrator, I want to view all active sessions and their current risk scores in real time, so that I can monitor system health and identify threats.	Dashboard refreshes every 30 seconds; each session shows user, IP, device, duration, and risk score; color-coded risk indicators.	Critical
US-07	As a system administrator, I want to receive real-time alerts when anomaly events exceed a configurable severity threshold, so that I can respond to threats promptly.	Alerts appear in dashboard within 10 seconds of anomaly event; include session details and recommended action; can be dismissed or escalated.	High
US-08	As a system administrator, I want to manually terminate any active session from the dashboard, so that I can immediately respond to confirmed security threats.	Session terminated within 2 seconds of admin action; user receives session-expired message; termination logged in audit trail.	High
US-09	As a system administrator, I want to configure anomaly detection thresholds (challenge and termination scores), so that I can tune the system sensitivity to match our risk tolerance.	Threshold changes applied immediately without restart; changes logged with admin ID and timestamp; validation prevents invalid values.	Medium
US-10	As a system administrator, I want to export audit logs for a specified date range, so that I can support compliance reporting and incident investigations.	Logs exportable as CSV/JSON; include all session events, anomaly events, and admin actions; export completed within 30 seconds for 30-day range.	Medium
US-11	As an ML engineer, I want to retrain the behavioral model on new session data, so that it remains accurate as user behavior evolves over time.	Retraining triggered manually or automatically; new model version deployed without downtime; accuracy metrics logged post-deployment.	High
US-12	As an ML engineer, I want users to flag false positive challenges, so that I can incorporate corrections into model retraining.	'This was me' feedback option available after step-up; feedback stored with session ID; incorporated into next retraining cycle.	Medium

Story ID	User Story	Acceptance Criteria	Priority
US-13	As a third-party developer, I want comprehensive API documentation with example requests and responses, so that I can integrate the SDK into my application efficiently.	OpenAPI 3.0 spec available; all endpoints documented with request/response schemas; sandbox environment provided; code examples in Python and JavaScript.	High
US-14	As a third-party developer, I want a JavaScript SDK that I can embed in my web application with minimal configuration, so that behavioral data collection is handled automatically.	SDK initialized with a single API key; collects events automatically; < 50 KB minified bundle size; compatible with major browsers (Chrome, Firefox, Safari, Edge).	High

Table 2.2 — User Stories with Acceptance Criteria

2.3 Use Case Descriptions

Detailed use case descriptions are provided for the five most critical system interactions. Each use case specifies preconditions, main flow, alternative flows, and postconditions.

UC-01 — Authenticate User & Initiate Behavioral Monitoring

Actor(s)	End User, Auth Service, Behavioral SDK
Precondition	User has a registered account. Application has the behavioral SDK integrated.
Postcondition	User is authenticated. Active session exists. Behavioral monitoring is active. Risk score initialized to 0.00.
Step	Main Flow
1	User navigates to the application login page.
2	User enters email address and password; submits the login form.
3	Client application sends POST /auth/login to the API Gateway.
4	Auth Service validates credentials against the User database.
5	Auth Service generates a signed JWT token with a 1-hour expiry.
6	Auth Service creates a new Session record with status 'active' and returns the JWT to the client.
7	Client application stores the JWT and activates the behavioral data collection SDK.
8	SDK begins capturing keystroke, mouse, and touch events asynchronously.
9	SDK transmits batched behavioral events to POST /events/behavioral every 15 seconds.
Ref.	Alternative / Exception Flow
Step 4 — Invalid Credentials	Auth Service returns HTTP 401. Client displays error message. Failed attempt counter incremented.
Step 4 — Account Locked	If failed attempts ≥ 5 , account locked for 30 minutes. HTTP 403 returned with logout message.

Ref.	Alternative / Exception Flow
Step 8 — First-time User	Behavioral profile does not yet exist. SDK still collects events; ML engine enters profile-building mode for first 5 sessions.

Table — UC-01: Authenticate User & Initiate Behavioral Monitoring

UC-02 — Real-Time Anomaly Detection & Risk Scoring

Actor(s)	Behavioral SDK, Behavior Collector, ML Inference Engine, Auth Service
Precondition	User has an active authenticated session. Behavioral profile exists for the user (minimum 5 prior sessions).
Postcondition	Session risk_score updated. Appropriate action triggered based on threshold evaluation.
Step	Main Flow
1	SDK continuously collects behavioral events (keystrokes, mouse movements, touch gestures).
2	Every 15 seconds, SDK batches events and sends to POST /events/behavioral.
3	Behavior Collector receives events, preprocesses raw data into a normalized feature vector.
4	Feature vector published to Kafka behavioral-events topic.
5	ML Inference Engine consumes the event from Kafka.
6	Engine retrieves the user's stored behavioral profile (feature vector baseline) from the Behavioral Profiles database.
7	Engine computes an anomaly score using the One-Class SVM model (score range: 0.00–1.00).
8	Anomaly score published to Kafka risk-scores topic.
9	Auth Service consumes risk score, updates the active session's risk_score in the Session database.
10	Auth Service evaluates the score against configured thresholds and takes appropriate action.
Ref.	Alternative / Exception Flow
Step 5 — ML Engine Unavailable	Auth Service applies a fallback rule — if 3 consecutive scoring cycles fail, risk score elevated to 0.60.
Step 6 — Profile Not Found	Behavioral profile not yet established. Score defaults to 0.10 (trusted new session). Profile-building continues.
Step 7 — Autoencoder Fallback	If SVM score is inconclusive (0.55–0.65), Autoencoder model provides secondary score; average is used.

Table — UC-02: Real-Time Anomaly Detection & Risk Scoring

UC-03 — Trigger Step-Up Authentication

Actor(s)	Auth Service, End User, OTP Service
Precondition	User has an active session. Session risk_score has exceeded the challenge threshold (> 0.65).

Postcondition	Session resumed with reset risk score (success) or session terminated (failure/timeout).
Step	Main Flow
1	Auth Service detects risk_score > 0.65 during threshold evaluation.
2	Auth Service updates session status to 'challenged'.
3	Auth Service sends a challenge trigger to the client application via WebSocket or next API response.
4	Client application displays the step-up authentication modal to the user.
5	OTP Service generates a 6-digit one-time password and sends it to the user's registered mobile number.
6	User receives OTP and enters it into the step-up modal within 30 seconds.
7	Client application sends POST /auth/step-up with the OTP and session ID.
8	Auth Service validates OTP via OTP Service.
9	OTP is valid: Auth Service resets session risk_score to 0.00, updates session status to 'active', and issues a refreshed JWT token.
10	Step-up event logged in AnomalyEvent and AuditLog tables.
Ref.	Alternative / Exception Flow
Step 6 — OTP Timeout	User does not submit OTP within 30 seconds. Session status set to 'terminated'. User redirected to login.
Step 8 — Invalid OTP	HTTP 401 returned. User allowed up to 3 attempts. On 3rd failure, session terminated and event escalated.
Step 8 — Risk Score > 0.90	Step-up not attempted; session terminated immediately (see UC-04).

Table — UC-03: Trigger Step-Up Authentication

UC-04 — Automatic Session Termination

Actor(s)	Auth Service, End User
Precondition	User has an active or challenged session. Risk score has exceeded the termination threshold (> 0.90).
Postcondition	Session terminated. JWT invalidated. User must re-authenticate. Security event logged and visible on admin dashboard.
Step	Main Flow
1	Auth Service detects risk_score > 0.90 during threshold evaluation.
2	Auth Service immediately invalidates the session JWT token.
3	Auth Service updates session status to 'terminated' and records termination_reason as 'high_risk'.
4	Auth Service publishes a session-terminated event to Kafka.
5	Client application receives session invalidation signal on next request (HTTP 401) or via WebSocket push.

Step	Main Flow
6	Client application clears local JWT storage and redirects user to the login page.
7	User is presented with a message: 'Your session was ended due to unusual activity. Please log in again.'
8	Termination event logged in AnomalyEvent table with full anomaly score history.
9	Admin dashboard updated in real time to reflect the terminated session.
Ref.	Alternative / Exception Flow
Step 1 — Escalation from Step-Up Failure	Session terminated after 3 failed OTP attempts even if score is below 0.90.
Step 5 — Offline Client	If client is offline, token invalidation takes effect on next server contact. Redis-based token blacklist ensures revocation.

Table — UC-04: Automatic Session Termination

UC-05 — Administrator Reviews & Responds to Anomaly Alert

Actor(s)	System Administrator, Admin Service, Auth Service
Precondition	Administrator is authenticated in the admin dashboard. An anomaly event has been generated.
Postcondition	Session terminated (or marked false positive). Action logged. Alert resolved. ML retraining queue updated if applicable.
Step	Main Flow
1	Admin dashboard receives real-time anomaly alert via WebSocket push from Admin Service.
2	Alert is displayed in the Anomaly Alerts feed with: user ID, session ID, risk score, timestamp, and event type.
3	Administrator clicks on the alert to view the Session Detail page.
4	Session Detail page displays: user metadata, behavioral anomaly score timeline chart, device fingerprint, IP address, full event log.
5	Administrator reviews the evidence and determines the session is suspicious.
6	Administrator clicks 'Terminate Session' button.
7	Admin Service sends POST /admin/sessions/{id}/terminate to Auth Service.
8	Auth Service invalidates session and returns confirmation.
9	Admin Service logs the administrative action in AuditLog with admin user ID, timestamp, and action.
10	Alert status updated to 'resolved — admin terminated'.
Ref.	Alternative / Exception Flow
Step 5 — False Positive Confirmed	Administrator determines session is legitimate. Clicks 'Mark as False Positive'. Event flagged for ML retraining.

Ref.	Alternative / Exception Flow
Step 6 — Session Already Terminated	System displays informational message. Admin action logged as 'no-op — already terminated'.

Table — UC-05: Administrator Reviews & Responds to Anomaly Alert

3. Functional Requirements

3.1 Overview

Functional requirements define the specific behaviors and capabilities the system must provide to satisfy stakeholder needs and user stories. Each requirement is assigned a unique identifier, a priority classification (Critical / High / Medium / Low), and is traceable to one or more user stories.

3.2 Authentication & Session Management

Req. ID	Requirement Description	Priority	Traces To
FR-AUTH-01	The system shall authenticate users by validating email and password credentials against securely hashed records in the User database.	Critical	US-01
FR-AUTH-02	The system shall issue a signed JWT access token upon successful authentication, valid for 60 minutes, containing user ID and session ID.	Critical	US-01
FR-AUTH-03	The system shall create and persist a Session record upon successful login, capturing start time, IP address, device fingerprint, and user agent.	Critical	US-01
FR-AUTH-04	The system shall support secure logout by invalidating the JWT token and updating the session status to 'terminated'.	High	US-01
FR-AUTH-05	The system shall enforce account lockout after 5 consecutive failed login attempts within a 10-minute window, locking the account for 30 minutes.	High	US-01
FR-AUTH-06	The system shall support token refresh, allowing clients to obtain a new JWT before expiry without requiring re-authentication.	Medium	US-01

Table — 3.2 Authentication & Session Management

3.3 Behavioral Data Collection

Req. ID	Requirement Description	Priority	Traces To
FR-COLL-01	The JavaScript SDK shall collect keystroke dynamics including key dwell time (key-down to key-up duration) and inter-key flight time.	Critical	US-02
FR-COLL-02	The JavaScript SDK shall collect mouse movement data including velocity, acceleration, trajectory curvature, and click timing intervals.	Critical	US-02
FR-COLL-03	The React Native mobile SDK shall collect touchscreen gesture data including tap pressure, swipe velocity, swipe direction, and multi-touch patterns.	High	US-02, US-14
FR-COLL-04	The SDK shall transmit batched behavioral events to the backend every 15 seconds using asynchronous, non-blocking HTTP POST requests.	Critical	US-02

Req. ID	Requirement Description	Priority	Traces To
FR-COLL-05	The SDK shall add no more than 5% performance overhead to the host application as measured by page load time and interaction latency.	Critical	US-02, US-14
FR-COLL-06	The SDK shall operate silently without any visible UI elements or user notifications during normal (non-challenge) sessions.	High	US-02
FR-COLL-07	The system shall drop and not store raw behavioral events after feature extraction; only normalized feature vectors shall be persisted.	Critical	US-02

Table — 3.3 Behavioral Data Collection

3.4 Behavioral Profile Management

Req. ID	Requirement Description	Priority	Traces To
FR-PROF-01	The system shall create an initial behavioral profile for each user after a minimum of 5 training sessions using a One-Class SVM model.	Critical	US-02, US-11
FR-PROF-02	The system shall store behavioral profiles as serialized feature vectors in the Behavioral Profiles database, versioned with a model type identifier.	High	US-11
FR-PROF-03	The system shall support incremental model retraining triggered manually by an ML engineer or automatically on a configurable schedule (default: monthly).	High	US-11, US-12
FR-PROF-04	The system shall accept and store user false-positive feedback, tagging affected sessions for inclusion in the next retraining cycle.	Medium	US-12
FR-PROF-05	The system shall maintain model version history, allowing rollback to a previous model version if a new deployment degrades accuracy.	Medium	US-11

Table — 3.4 Behavioral Profile Management

3.5 Anomaly Detection & Risk Scoring

Req. ID	Requirement Description	Priority	Traces To
FR-RISK-01	The ML Inference Engine shall compute a normalized anomaly score (0.00–1.00) for each received behavioral event batch using the user's active behavioral profile.	Critical	US-02, US-03
FR-RISK-02	The system shall update the active session's risk_score in the Session database within 5 seconds of receiving a behavioral event batch.	Critical	US-02, US-03

Req. ID	Requirement Description	Priority	Traces To
FR-RISK-03	When the One-Class SVM anomaly score falls in the inconclusive range (0.55–0.65), the system shall apply an Autoencoder model as a secondary classifier and use the average of both scores.	High	US-03
FR-RISK-04	The system shall log every risk score computation as an AnomalyEvent record, including timestamp, score, model version, and contributing feature weights.	High	US-06, US-10
FR-RISK-05	Administrators shall be able to configure the challenge threshold (default: 0.65) and termination threshold (default: 0.90) via the admin dashboard without system restart.	High	US-09

Table — 3.5 Anomaly Detection & Risk Scoring

3.6 Adaptive Response — Step-Up Authentication

Req. ID	Requirement Description	Priority	Traces To
FR-STEP-01	The system shall trigger a step-up authentication challenge when the session risk_score exceeds the configured challenge threshold (default: 0.65).	Critical	US-03, US-04
FR-STEP-02	The system shall generate and deliver a 6-digit OTP to the user's registered mobile number within 5 seconds of a step-up trigger.	Critical	US-04
FR-STEP-03	The OTP shall expire after 30 seconds. The system shall reject expired OTPs and optionally resend on user request.	Critical	US-04
FR-STEP-04	Upon successful OTP validation, the system shall reset the session risk_score to 0.00, restore session status to 'active', and issue a refreshed JWT token.	Critical	US-04
FR-STEP-05	The system shall terminate the session after 3 consecutive failed OTP verification attempts and log the event as a high-severity AnomalyEvent.	High	US-04, US-05
FR-STEP-06	The step-up authentication modal shall support alternative verification methods: TOTP authenticator app and email OTP, as configurable fallbacks.	Medium	US-04

Table — 3.6 Adaptive Response — Step-Up Authentication

3.7 Automatic Session Termination

Req. ID	Requirement Description	Priority	Traces To
FR-TERM-01	The system shall immediately terminate a session and invalidate the associated JWT token when the risk_score exceeds the termination threshold (default: 0.90).	Critical	US-05

Req. ID	Requirement Description	Priority	Traces To
FR-TERM-02	Upon session termination, the client application shall receive an HTTP 401 response or WebSocket push notification within 2 seconds.	Critical	US-05
FR-TERM-03	The system shall add the invalidated JWT token to a Redis-based token blacklist to prevent further use, even before token natural expiry.	Critical	US-05
FR-TERM-04	The terminated session shall be logged in both the Session table (status='terminated', termination_reason) and as an AnomalyEvent record.	High	US-05, US-10

Table — 3.7 Automatic Session Termination

3.8 Admin Dashboard & Monitoring

Req. ID	Requirement Description	Priority	Traces To
FR-ADMIN-01	The admin dashboard shall display a real-time list of all active sessions, updating every 30 seconds, showing: user, IP, device, session duration, and current risk score.	Critical	US-06
FR-ADMIN-02	The dashboard shall display a real-time anomaly alert feed, with new alerts pushed within 10 seconds of event generation via WebSocket.	Critical	US-07
FR-ADMIN-03	Each anomaly alert shall include: user ID, session ID, timestamp, risk score, event type, and a recommended action.	High	US-07
FR-ADMIN-04	The dashboard shall provide a Session Detail view showing: user metadata, risk score time-series chart, device fingerprint, IP geolocation, and full event log.	High	US-08
FR-ADMIN-05	Administrators shall be able to manually terminate any active session from the dashboard; termination shall be effective within 2 seconds.	Critical	US-08
FR-ADMIN-06	Administrators shall be able to export audit logs for a configurable date range as CSV or JSON, with download completing within 30 seconds for a 30-day range.	Medium	US-10
FR-ADMIN-07	The dashboard shall display top-level KPI metrics: total active sessions, anomaly events (last 24h), average risk score, and model accuracy.	Medium	US-06

Table — 3.8 Admin Dashboard & Monitoring

3.9 API & Integration

Req. ID	Requirement Description	Priority	Traces To
FR-API-01	The system shall expose RESTful APIs conforming to the OpenAPI 3.0 specification, covering all authentication, behavioral event, and administration endpoints.	Critical	US-13

Req. ID	Requirement Description	Priority	Traces To
FR-API-02	All API endpoints (except /auth/login) shall require a valid Bearer JWT token for authentication.	Critical	US-13
FR-API-03	The API Gateway shall enforce per-client rate limits of 1,000 requests per minute for behavioral event endpoints to prevent abuse.	High	US-13
FR-API-04	The JavaScript SDK shall be distributable as a standalone script tag inclusion and as an npm package, compatible with Chrome 90+, Firefox 88+, Safari 14+, and Edge 90+.	High	US-14
FR-API-05	A sandbox / staging API environment shall be provided for third-party developers to test integrations without affecting production data.	Medium	US-13

Table — 3.9 API & Integration

4. Non-Functional Requirements

4.1 Overview

Non-functional requirements (NFRs) define the quality attributes and operational constraints the system must satisfy. They complement the functional requirements by specifying how the system performs its functions — not just what it does. NFRs are organized into six categories: Performance, Security, Usability, Reliability, Scalability, and Maintainability.

4.2 Performance Requirements

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-PERF-01	API Response Time	The behavioral analysis API endpoint (POST /events/behavioral) shall respond within 200ms at the 95th percentile (p95) under normal load conditions (up to 5,000 concurrent users).	Measure p95 response time using k6 load testing. Baseline: 5,000 virtual users, 15-second ramp-up.	Critical
NFR-PERF-02	Risk Score Update Latency	The end-to-end latency from behavioral event submission to session risk score update shall not exceed 5 seconds under all normal operating conditions.	Timestamp event submission vs. session risk_score update timestamp in database logs.	Critical
NFR-PERF-03	SDK Performance Overhead	The behavioral collection SDK shall introduce no more than 5% overhead on host application page load time and no more than 3% overhead on user interaction responsiveness.	Lighthouse performance audit with and without SDK enabled. Measure FCP and TBT metrics.	Critical
NFR-PERF-04	Event Processing Throughput	The Behavior Collector service shall process a minimum of 5,000 behavioral event batches per second without message loss or queue backlog exceeding 60 seconds.	Monitor Kafka consumer lag (target: < 60 seconds). Measure throughput with k6 event simulation.	High
NFR-PERF-05	Admin Dashboard Load Time	The admin dashboard shall load and display current session data within 3 seconds on a standard broadband connection (> 10 Mbps).	Chrome DevTools performance profiling. Measure Time to Interactive (TTI).	Medium

Table — 4.2 Performance Requirements

4.3 Security Requirements

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-SEC-01	Data Encryption in Transit	All data transmitted between system components (client-to-API, service-to-service, API-to-database) shall be encrypted using TLS 1.3 or higher. TLS 1.1 and 1.2 shall be explicitly disabled.	SSL/TLS configuration audit using testssl.sh. Verify TLS 1.3 enforcement on all endpoints.	Critical
NFR-SEC-02	Data Encryption at Rest	All sensitive data at rest — including user credentials, behavioral feature vectors, and audit logs — shall be encrypted using AES-256 encryption in the managed database service.	AWS RDS encryption-at-rest configuration audit. Verify encryption key management via AWS KMS.	Critical
NFR-SEC-03	Authentication Token Security	JWT tokens shall be signed using RS256 (RSA 2048-bit). Tokens shall include expiry (60 min), issued-at, and session ID claims. Tokens shall be invalidated on the server side upon logout or session termination.	JWT inspection and key length verification. Test invalidation by attempting to use a logged-out token.	Critical
NFR-SEC-04	Input Validation & Injection Prevention	All API endpoints shall validate and sanitize inputs to prevent SQL injection, XSS, and NoSQL injection attacks. Parameterized queries shall be used for all database interactions.	OWASP ZAP automated security scan. Manual penetration testing of all API endpoints.	Critical
NFR-SEC-05	Behavioral Data Privacy	Raw behavioral event data (keystrokes, mouse coordinates, touch points) shall not be persisted to any storage medium. Only normalized, anonymized feature vectors shall be stored, with no possibility of reconstructing original input sequences.	Code review of Behavior Collector service. Verify only feature vectors reach the database.	Critical
NFR-SEC-06	Role-Based Access Control	The system shall enforce RBAC with a minimum of three roles: End User (session access only), Administrator (full dashboard + config access), and System (internal service-to-service access).	Attempt to access admin endpoints with End User token — expect HTTP 403. Verify role enforcement.	High
NFR-SEC-07	Security Vulnerability Scanning	All Docker container images shall be scanned for known CVEs before deployment using Trivy or equivalent. No Critical or High severity CVEs shall be present in production images.	Integrate Trivy in CI/CD pipeline. Gate production deployment on zero Critical/High CVEs.	High

Table — 4.3 Security Requirements

4.4 Usability Requirements

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-USE-01	Transparency to End Users	The behavioral monitoring system shall operate entirely in the background during normal sessions. No UI elements, loading indicators, or notifications related to monitoring shall be visible to the end user unless a step-up challenge is triggered.	User observation sessions: confirm no behavioral monitoring UI visible during normal use.	Critical
NFR-USE-02	Step-Up Authentication Clarity	When a step-up challenge is triggered, the prompt shall clearly state the reason ('Unusual activity detected'), the action required, and the time remaining before timeout. The message shall be written in plain language at a 6th-grade reading level.	Readability score analysis (Flesch-Kincaid). User testing with 5 participants from target demographic.	High
NFR-USE-03	Admin Dashboard Learnability	A new system administrator with no prior system-specific training shall be able to navigate to the anomaly alert feed, view session details, and terminate a session within 10 minutes of first accessing the dashboard.	Usability test: task completion time measurement with 3 new admin-role participants.	High
NFR-USE-04	Accessibility	The admin dashboard and step-up authentication UI shall comply with WCAG 2.1 Level AA accessibility standards, including keyboard navigation, screen reader compatibility, and minimum 4.5:1 color contrast ratios.	Automated accessibility audit using axe-core. Manual keyboard navigation testing.	Medium
NFR-USE-05	Error Message Clarity	All error messages presented to end users (invalid login, OTP failure, session expired) shall be clear, actionable, and free of technical jargon. Error codes shall be included for support escalation.	Content review of all user-facing error states against plain language guidelines.	Medium

Table — 4.4 Usability Requirements

4.5 Reliability Requirements

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-REL-01	System Uptime	The authentication service shall maintain a minimum availability of 99.9% (allowing for a maximum of ~8.7 hours downtime per year), measured on a rolling 30-day basis.	Uptime monitoring via AWS CloudWatch and Kubernetes liveness probes. Monthly SLA report.	Critical

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-REL-02	Fault Isolation	A failure in any single microservice (e.g., ML Inference Engine) shall not cause a complete system outage. The system shall degrade gracefully — falling back to rule-based risk scoring if ML scoring is unavailable.	Chaos engineering test: kill ML Inference Engine pod; verify Auth Service applies fallback rule and continues serving sessions.	Critical
NFR-REL-03	Data Durability	The primary PostgreSQL database shall be configured with Multi-AZ deployment. Daily automated snapshots shall be retained for a minimum of 30 days. Recovery Point Objective (RPO) shall not exceed 15 minutes.	Test database failover by simulating primary node failure. Verify failover completes in < 60 seconds.	Critical
NFR-REL-04	Mean Time to Recovery (MTTR)	In the event of an unplanned service outage, the Mean Time to Recovery shall not exceed 30 minutes for Severity 1 (full service unavailable) incidents.	Incident response drill: simulate service outage and measure time to restore full functionality.	High
NFR-REL-05	Kafka Message Durability	Behavioral event messages published to Kafka shall be replicated across a minimum of 3 brokers with a replication factor of 3. No message shall be lost in the event of a single broker failure.	Kill one Kafka broker; verify all in-flight messages are delivered and consumed without loss.	High

Table — 4.5 Reliability Requirements

4.6 Scalability Requirements

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-SCALE-01	Horizontal Scaling	The Auth Service, Behavior Collector, and ML Inference Engine shall support horizontal scaling via Kubernetes Horizontal Pod Autoscaler (HPA), scaling out automatically when CPU utilization exceeds 70% or Kafka consumer lag exceeds 30 seconds.	Load test scaling behavior: ramp load from 0 to 10,000 concurrent users; verify HPA triggers within 2 minutes.	Critical
NFR-SCALE-02	Concurrent Session Capacity	The system shall support a minimum of 10,000 simultaneously active authenticated sessions with behavioral monitoring enabled, without degradation of p95 API response time beyond 200ms.	k6 load test with 10,000 concurrent virtual users performing continuous behavioral event submission.	Critical

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-SCALE-03	Database Scalability	Read-heavy database operations (session lookups, profile retrievals) shall be served by PostgreSQL read replicas to distribute load. Connection pooling (PgBouncer) shall cap connections at 100 per service instance.	Monitor pg_stat_activity during load tests. Verify read replicas are serving select queries.	High
NFR-SCALE-04	Stateless Service Design	All microservices shall be designed as stateless components. Session state and cached data shall be stored in Redis, not in service memory, to enable seamless horizontal scaling.	Code review for in-memory state. Test: scale service to 0 replicas and back; verify no session data loss.	High

Table — 4.6 Scalability Requirements

4.7 Maintainability Requirements

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-MAINT-01	Code Quality & Standards	All Python backend code shall adhere to PEP 8 standards and achieve a minimum Pylint score of 8.0/10. JavaScript/TypeScript code shall pass ESLint with no errors using the Airbnb style guide configuration.	Pylint and ESLint reports generated in CI pipeline. Gate on minimum score thresholds.	High
NFR-MAINT-02	Test Coverage	Automated unit and integration test suites shall achieve a minimum line coverage of 85% for all backend services. Coverage reports shall be generated and reviewed on every CI build.	pytest-cov / Jest coverage reports in GitHub Actions CI. Gate on 85% threshold.	High
NFR-MAINT-03	Modularity & Separation of Concerns	The system shall be designed with a strict separation of concerns: the ML Inference Engine shall be independently deployable and replaceable without changes to the Auth Service or Behavior Collector.	Architecture review: verify ML Engine is consumed only via defined API/Kafka interface. Test independent deployment.	High
NFR-MAINT-04	Logging & Observability	All microservices shall emit structured JSON logs (including trace ID, service name, log level, and timestamp) to a centralized logging platform (e.g., AWS CloudWatch Logs). All logs shall be searchable and retained for a minimum of 90 days.	Verify log format compliance. Search logs for a known trace ID spanning multiple services.	High

NFR ID	Attribute	Requirement	Verification Method	Priority
NFR-MAINT-05	Documentation Currency	All system components shall have up-to-date technical documentation (API specs, architecture diagrams, deployment runbooks) maintained in the project wiki. Documentation shall be updated as part of the Definition of Done for each sprint.	Documentation audit at each milestone gate. Verify no component is deployed without updated documentation.	Medium
NFR-MAINT-06	Infrastructure as Code	All cloud infrastructure shall be provisioned and managed via Terraform scripts stored in version control. Manual infrastructure changes shall be prohibited in production environments.	Audit AWS console for resources not managed by Terraform. Enforce via AWS Config rules.	Medium

Table — 4.7 Maintainability Requirements